

情報セキュリティ規程（雛形）

情報セキュリティ規程

第 1 章 総則

第 1 条（目的）

本規程は、株式会社〇〇（以下「会社」という）における情報資産の機密性、完全性、可用性を確保し、情報セキュリティ incidents の未然防止および迅速な対応を図ることを目的とする。

第 2 条（適用範囲）

本規程は、会社の全役員および従業員（正社員、契約社員、パートタイマー、派遣社員等を含む）に適用する。

第 3 条（定義）

本規程において使用する用語の定義は、次のとおりとする。

1. **情報資産**: 会社が保有するすべての情報および情報システム
 2. **情報セキュリティ**: 情報の機密性、完全性、可用性を維持すること
 3. **機密性**: 認められた者だけが情報にアクセスできること
 4. **完全性**: 情報および処理方法が正確であること
 5. **可用性**: 認められた必要な時に、情報にアクセスできること
 6. **インシデント**: 情報セキュリティに影響を与える事象
-

第 2 章 情報セキュリティ基本方針

第 4 条（基本方針）

会社は、次の基本方針に基づき、情報セキュリティを確保する。

1. 情報資産を適切に管理し、その価値を維持する
2. 法令および契約上の要求事項を遵守する
3. 情報セキュリティインシデントを未然に防止する
4. インシデント発生時は迅速かつ適切に対応する
5. 情報セキュリティに関する意識向上を図る

第 5 条 (情報セキュリティ責任者)

会社は、情報セキュリティ責任者（CISO）を置き、情報セキュリティに関する総括的な責任を負うものとする。

第 3 章 情報資産の分類と管理

第 6 条 (情報資産の分類)

情報資産は、次のとおり分類する。

1. **極秘**: 会社の存続に関わる情報（経営戦略、特許、財務情報等）
2. **機密**: 業務上重要な情報（顧客情報、契約書、技術情報等）
3. **社外秘**: 社外への公開を制限すべき情報（社内規定、組織図等）
4. **公開**: 社外に公開可能な情報（会社案内、プレスリリース等）

第 7 条 (情報資産の管理)

従業員は、情報資産をその分類に応じて適切に管理しなければならない。

1. 極秘情報は、厳重なアクセス制御を行う
 2. 機密情報は、必要最小限の者のみアクセスを許可する
 3. 社外秘情報は、社外への持ち出しを制限する
 4. 公開情報は、正確性を確保して公開する
-

第 4 章 物理的セキュリティ

第 8 条 (入退室管理)

1. オフィスへの入退室は、ID カード等により管理する
2. 来訪者は、受付で登録し、従業員の同伴のもとオフィスに入室する
3. サーバ室等の重要エリアは、特別な許可がない限り立ち入りを禁止する

第 9 条 (設備管理)

1. 情報処理設備は、適切な環境（温度、湿度、電源等）で管理する
2. 重要な設備には、適切な防災・防犯対策を講じる
3. 廃棄する設備は、データを完全に消去する

第 10 条 (デスクセキュリティ **)

1. 離席時は、PC 画面をロックする
 2. 机上の重要書類は、施錠可能なキャビネットに保管する
 3. 印刷物は、必要最小限とし、速やかに回収する
-

第 5 章 技術的セキュリティ

第 11 条 (アクセス制御)

1. 情報システムへのアクセスは、ユーザー ID およびパスワードにより認証する
2. パスワードは、8 文字以上の英数字記号を組み合わせで設定する
3. パスワードは、90 日ごとに変更する
4. 共有 ID の使用は、原則として禁止する

第 12 条 (ネットワークセキュリティ)

1. 社内ネットワークと外部ネットワークは、ファイアウォールで分離する
2. 外部からのアクセスは、VPN を使用する
3. 無線 LAN は、暗号化し、認証を必須とする

第 13 条 (マルウェア対策 **)

1. 全端末にウイルス対策ソフトを導入し、常に最新の状態に保つ
2. 不審なメール、添付ファイルは開かない
3. 外部メディア (USB 等) の使用は、セキュリティチェックを受ける

第 14 条 (バックアップ)

1. 重要なデータは、定期的にバックアップを取得する
 2. バックアップデータは、暗号化して別の場所に保管する
 3. バックアップの復旧テストを定期的実施する
-

第 6 章 人的セキュリティ

第 15 条 (セキュリティ教育)

1. 従業員は、入社時に情報セキュリティ教育を受講する
2. 年 1 回以上、定期的なセキュリティ教育を実施する
3. セキュリティインシデントの事例を共有し、意識向上を図る

第 16 条 (秘密保持契約)

1. 従業員は、入社時に秘密保持契約を締結する
2. 退職後も、在職中に知得した秘密情報を漏洩してはならない
3. 業務委託先等には、秘密保持契約の締結を義務付ける

第 17 条 (持ち出し制限)

1. 情報資産の社外への持ち出しは、上司の承認を得る
 2. 持ち出し時は、暗号化等の適切な保護措置を講じる
 3. 持ち出した情報資産は、速やかに返却または廃棄する
-

第 7 章 インシデント対応

第 18 条 (インシデントの報告)

情報セキュリティインシデントまたはその兆候を発見した場合、直ちに情報システム部門に報告しなければならない。

第 19 条 (インシデント対応)

1. 情報システム部門は、報告を受けた場合、直ちに調査を開始する
2. 影響範囲の特定、原因究明、被害の拡大防止に努める
3. 必要に応じ、関係部署および経営層に報告する

第 20 条 (再発防止)

1. インシデントの原因を分析し、再発防止策を策定する
 2. 必要に応じ、本規程および関連規定を見直す
 3. 従業員への周知徹底を図る
-

第 8 章 監査および見直し

第 21 条 (内部監査)

会社は、情報セキュリティの状況について、年 1 回以上、内部監査を実施する。

第 22 条 (外部監査)

法令または契約により外部監査が必要な場合、これを受けるものとする。

第 23 条 (規程の見直し)

本規程は、年 1 回以上、定期的に見直し、必要に応じて改訂する。

第 9 章 罰則

第 24 条 (違反時の措置)

本規程に違反した場合、会社は就業規則等に基づき、懲戒処分を行うことができる。ただし、違反が悪質な場合、刑事責任を問うことがある。

第 10 章 雑則

第 25 条 (細則)

本規程の実施に関し必要な事項は、別に定める。

第 26 条（施行日）

本規程は、2025 年 4 月 1 日から施行する。

制定日：2025 年 2 月 25 日 株式会社〇〇